

Session 7 lab — RBAC scope, Conditional Access, defense in depth

Time: 30 minutes **Objectives practiced:** 2.4.1–2.4.8 **You need:** paper for Parts A and C. Portal only if the instructor opens a tenant where role assignment is allowed.

Part A — What can they do? (10 minutes)

A resource group `payroll` contains a storage account and a virtual machine. It sits in subscription `Finance`. `Finance` sits under management group `Corp`.

Answer each in one line. Say what they can see or change, and name the scope that made it true.

1. Alex is assigned Reader at `Finance`. Can Alex see the virtual machine in `payroll`? Can Alex restart it?
2. Blake is assigned Contributor on `payroll` only. Can Blake create a new resource in a different resource group in `Finance`?
3. Blake is Contributor on `payroll`. Can Blake assign Reader to a coworker on that virtual machine?
4. Casey is assigned Owner at management group `Corp`. Does that include `payroll`? Why?
5. Dana is assigned Reader on the storage account only. Can Dana open the virtual machine in the same resource group?

Part B — Portal, if available (10 minutes)

Guided project, start only the slice the instructor rehearsed: [Set up new employee access](#).

Otherwise:

1. Open a built-in role (Reader) and read its description. Do not assign it unless told to.
2. Open Conditional Access templates, read only. Many tenants cannot save a policy without a license. Reading the template is the task: find one signal and one control.
3. Open Microsoft Defender for Cloud far enough to see secure score or recommendations. If the blade is empty, write "no recommendations in this subscription" and move on.

No-cost path

Skip Part B. Read [Azure RBAC overview](#) and complete Part A from the inheritance description there. The instructor projects a role blade.

Part C — Which layer? (10 minutes)

Write one layer: **physical, identity, perimeter, network, compute, application, data**.

1. Badge readers at the datacenter door.
2. Multifactor authentication.
3. A firewall at the edge of the network.
4. A network security group on a subnet.

5. Patching the operating system on a virtual machine you manage.
6. Input checking in the application code.
7. Encryption of the data stored in the account.
8. A Conditional Access policy that blocks unfamiliar sign-ins.

Instructor key

Part A

1. Alex can see the VM and cannot restart it. Reader at the subscription inherits down. Reader does not change resources.
2. No. Contributor on `payroll` stops at that resource group.
3. No. Contributor does not assign roles. Owner does.
4. Yes. `Corp` is above `Finance`, which is above `payroll`. Inheritance moves down.
5. No. The assignment is the storage account only. Sibling resources are not included.

Part C

1. Physical
2. Identity
3. Perimeter
4. Network
5. Compute
6. Application
7. Data
8. Identity

Conditional Access is identity and access, not perimeter.